GDPR Principles

arnaud.nauwynck@gmail.com

What is GDPR

You

what is GDPR ?

ChatGPT

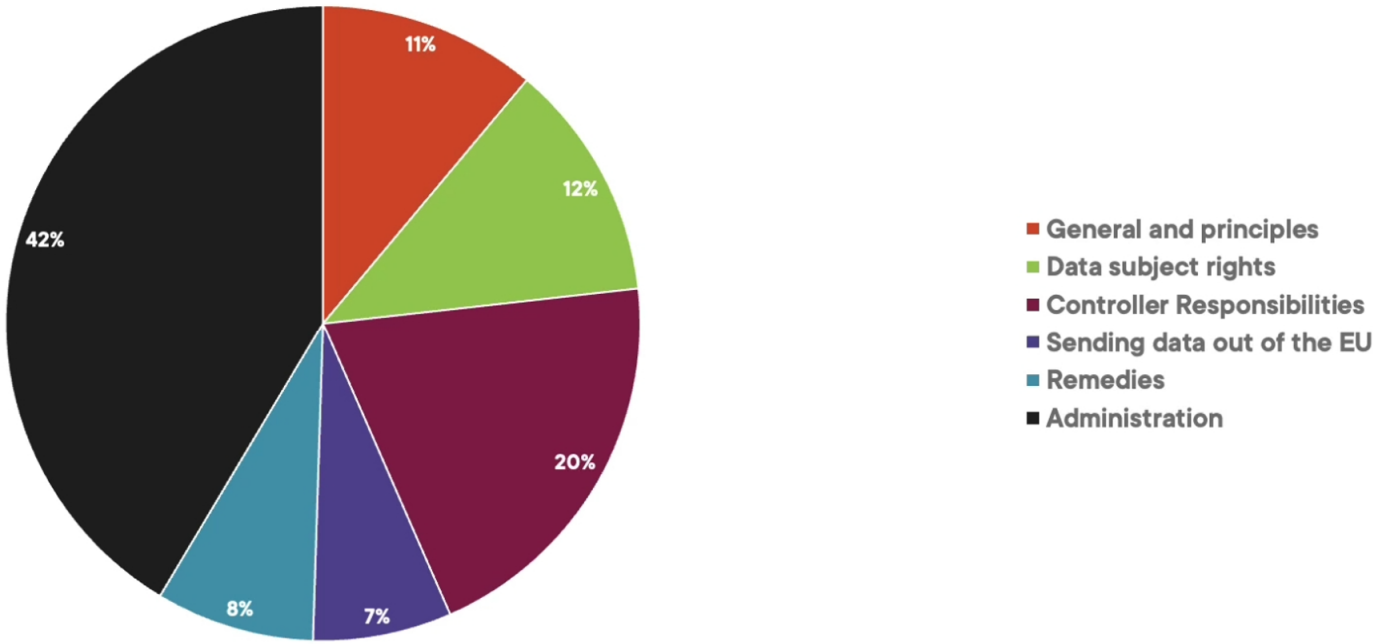
GDPR stands for the General Data Protection Regulation. It is a comprehensive data protection regulation enacted by the European Union (EU) in May 2018. The GDPR is designed to strengthen and unify data protection for individuals within the EU, as well as regulate the export of personal data outside the EU and European Economic Area (EEA).

Key aspects of the GDPR include:

1. **Expanded Scope**: The GDPR applies not only to organizations located within the EU but also to organizations outside the EU that offer goods or services to, or monitor the behavior of, individuals within the EU.
2. **Enhanced Individual Rights**: It grants individuals greater control over their personal data, including the right to access their data, request rectification or erasure of their data (the "right to be forgotten"), and object to processing of their data.
3. **Accountability and Governance**: Organizations are required to implement measures to ensure compliance with the GDPR, including data protection policies, privacy impact assessments, and maintaining records of processing activities. Data controllers and processors are held accountable for ensuring that personal data is processed lawfully, transparently, and securely.
4. **Data Breach Notification**: Organizations are required to notify data protection authorities of data breaches without undue delay and, where feasible, within 72 hours of becoming aware of the breach. Individuals affected by a data breach must also be notified if the breach is likely to result in a high risk to their rights and freedoms.
5. **Data Protection Impact Assessments (DPIAs)**: Organizations are required to conduct DPIAs for processing operations that are likely to result in a high risk to individuals' privacy, such as systematic monitoring or large-scale processing of sensitive data.
6. **Data Protection Officers (DPOs)**: Some organizations are required to appoint a Data Protection Officer to oversee GDPR compliance, particularly public authorities, organizations engaged in large-scale systematic monitoring or processing of sensitive data, and those whose core activities involve processing data on a large scale.
7. **Cross-Border Data Transfers**: The GDPR imposes restrictions on transferring personal data outside the EU and EEA to countries that do not provide an adequate level of data protection unless appropriate safeguards are in place.
8. **Significant Penalties**: Non-compliance with the GDPR can result in significant fines of up to €20 million or 4% of the organization's global annual turnover, whichever is higher.

Overall, the GDPR aims to harmonize data protection laws across the EU, strengthen individuals' privacy rights, and promote responsible and transparent handling of personal data by organizations.

99 articles !


11%
12%
20%
7%
8%
42%
General and principles
Data subject rights
Controller Responsibilities
Sending data out of the EU
Remedies
Administration

Terms

Data Subjects = living individuals in EU

Data Controller = giving order to process data

Data Processor = processing the data as specified by controller (ex: cloud provider)

Principle 1 : OK to use data

Using Data is legal, fair and expected

BUT living individual also have freedom rights,
including rights for their personnal data

So balance both

Balance


cultural, religious and linguistic diversity
an effective remedy and to a fair trial
freedom to conduct a business
freedom of expression and information
physical and mental integrity
freedom of thought, conscience and religion
respect for private and family life, home and communications
life
the protection of personal data
Doing anything with Personal Data
General Data Protection Regulation

Restriction Principles

Only collect for **specific purpose**

Only **necessary** data (not more)

Data must be **accurate**

Delete when **finish**

Secure (measure risk for end-users)

Be **accountable**

Lawfull, Fair, Transparent

Transparent: tell people what you're doing with data

Fair: balance people rights with interrest of organisation with processing data

Lawfull : process for one of 6 specified reasons :

- consent
- contract
- legal obligation
- vital interrest
- official
- legitimate interrests

Special Category Data

Discrimation

Biometric

Health

Sexual orientation

Processing Special Data? ... if
explicit consent, employment, vital interest, public interest, public health, what an organisation does

Purpose Limitation

do not collect anything "just in case"

use data for the purpose you declare it, nothing more

Minimalist Data Needs

strictly minimal for what is necessary for the processing

use **pseudonimisation** (reversible, ~index)
or **anonymisation** (irreversible, ~random)

Accurate

Data must be **accurate**, and **up to date**

Users can ask for review / corrections

Purge / Expire Data : Time Limit

retention for business / legal need ... ask

then automatically delete data after

Integrity and Confidentiality

process securely for the end-users

protect against unauthorized, unlawfull processing
warn for data loss, damage

(the CIA triad)

Accountability

The Data Controller (cf next) is responsible for respecting the principles and must demonstrate compliance, collaborate with authority

Must Provide

Who is the Data Controller ?
and who is the DPO

Purpose and legal basis

Legitimate interrest

Other recipient

International Transfers (ex: public cloud?)

Must Provide (... next)

Retention period

Statement of Right

Notification of the right to complain

Special rights if consent used

Whether obligated to provide data

Use of automated decision-making

Right To Know

Article 13 : right to know before giving your personnal data

Article 14: right to know when a controller get personnal data from elsewhere

Right to Correct/Delete/Stop

Article 15 : right to **know(copy)** the data

Article 16 : right to **correct** if inacurate

Article 17: **delete** if possible

Article 18 : **stop** doing that with data

... with 1 month delay max, and free

Governance Obligations

Article 24 : Accountability and governance

Article 25 : Protection by design

Article 30 : Records of Processing Activity (Audit)

Article 31 : Cooperate with Regulators

Accountability

things must be understood, organized,
with written policies,
folllowed by the organization structure

Protection By Default & By Design

minimize Data

audit every field :
do you really need each field, each line ?
if yes, could it be pseudonimized / anonymized ?

minimize Data security Access to required minimum
Who needs to see it ?
keep audit of who has read/write access

Secure proportionally to Risk of end-users

take into account
- state of the art security
- cost
- risk
- impacts

.. in the context of end-users risk x impacts

Record of Processing Activities

keep audit of :

What data is processed,
pupose and legal basis
Retention periods, security measures

can be requested by the regulator
(not required id "occasional" or very small organizations)

DPIA (Data Protection Impact Assessment)

You
what is DPIA ?

ChatGPT
DPIA stands for Data Protection Impact Assessment. It is a process used by organizations to identify and assess the potential risks associated with processing personal data. DPIAs are a key component of privacy by design and are mandated by the General Data Protection Regulation (GDPR) for certain types of processing activities.

The main objectives of conducting a DPIA include:

1. **Identifying Risks**: DPIAs help organizations identify and understand the risks to individuals' privacy associated with a particular data processing activity. This includes risks such as unauthorized access, data breaches, inaccuracies, and other potential negative impacts on individuals' rights and freedoms.
2. **Evaluating Necessity and Proportionality**: DPIAs assess whether the proposed data processing activity is necessary and proportionate to achieve its intended purpose. This involves considering alternative ways to achieve the same objectives with less impact on individuals' privacy.
3. **Mitigating Risks**: DPIAs enable organizations to identify measures to mitigate or minimize the identified risks. This may involve implementing technical and organizational safeguards, such as encryption, access controls, data minimization, and pseudonymization, to protect personal data and mitigate potential privacy risks.
4. **Demonstrating Compliance**: Conducting a DPIA demonstrates an organization's commitment to data protection and compliance with legal requirements, such as the GDPR. It helps organizations document their data protection efforts and provides evidence of accountability to data protection authorities and other stakeholders.
5. **Enhancing Transparency**: DPIAs promote transparency by involving stakeholders, including data subjects, in the decision-making process regarding the processing of their personal data. This can help build trust and confidence in how organizations handle personal data.

DPIAs typically involve a structured and systematic assessment process, which may include the following steps:

DPIA ... Mandatory if

processing and profiling that causes significant effect

large scale special category data (health, ..)

Public area monitoring

Data Controller | Processor

Data Processor = an entity that processes personal data on behalf of a Controller (third party / supplier / outsourcer / cloud provider)

Data Controller = an entity that determine a processing of a personnal data

Data { Controller |Processor }

Article 28 : Controller must manage Processors

Article 29 : Processors must do nothing else

must be contract / scope of service
sub-processors? must be agreed by Controller

Processor must help Controller/Data Subjects for obligations/rights

Do what you Say

Article 32:

You are responsible that
everybody does what is says with the data he has access to

DPO : Data Protection Officer

Article 37 : you must name a (competent) DPO

Article 38 : DPO has rights and responsibilities

Article 39 : a DPO has specific tasks

Security

Article 32 : appropriate technical & organizatinoal security

Article 33 : notify Regulator (72H) if personal data breach

Article 34: Notify data subjects if personal data breach

Risk

Impact (for end-users)

1=minor ex: disclosure of info
2=low ex: disclosure of special category data
3=medium ex:theft of identity
4=high ex: irretrieval control of sensitive data
5=critical ex: life changing



Probability

1=unlikely
2=possible
..
5=certain



Number of Subjects

Questions